

Cybersecurity Daily Newsletter

Vol. 006 | 2026-10-10 09:00 WIB

Top 5 Highlights

- FBI Arrests Founder of Ransomware Negotiation Firm
- ASOS Breach Reveals the Risks in Customer-Facing SaaS
- Small construction firm collapses after ransomware attack, while another narrowly avoids disaster
- Hunt.io finds BraZetsu infrastructure evolved beyond initial reports
- Malware preinstalled on cheap Android phones generates ad fraud

Threat Intelligence (10)

01. Hunt.io finds BraZetsu infrastructure evolved beyond initial reports

As reported by Security Affairs, Hunt.io's analysis of the BraZetsu initial access broker reveals that its underlying infrastructure continued to evolve and adapt months before public indicators of compromise (IOCs) became outdated.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources:

<https://www.scworld.com/brief/hunt-io-finds-brazetsu-infrastructure-evolved-beyond-initial-reports>

02. Malware preinstalled on cheap Android phones generates ad fraud

Malware has been discovered preinstalled on thousands of inexpensive Android phones, capable of generating fraudulent ad revenue and potentially turning infected devices into components of larger botnets, based on information published by The Record.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources:

<https://www.scworld.com/brief/malware-preinstalled-on-cheap-android-phones-generates-ad-fraud>

03. FakeGit campaign reactivates, distributing SmartLoader malware via GitHub

More than 17,000 fake repositories on GitHub are currently distributing the SmartLoader malware, a reactivation of the FakeGit campaign that began earlier this month to push the StealC infostealer, with further coverage provided by Bleeping Computer.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.scworld.com/brief/fakegit-campaign-reactivates-distributing-smartloader-malware-via-github>

04. Google Domains Impacted by Recent ccTLD Hijacks

Hackers hijacked the .gh, .sl, and .as ccTLDs and obtained HTTPS certificates for several Google domains. The post Google Domains Impacted by Recent ccTLD Hijacks appeared first on SecurityWeek .

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.securityweek.com/google-domains-impacted-by-recent-cctld-domain-hijacks/>

05. [+24h Old] Pre-Baked Firmware Malware Hits Budget Android Devices in 150+ Countries

Midnight Mimosa is the name given to a malware campaign primarily running preinstalled on low-cost Android devices. The post Pre-Baked Firmware Malware Hits Budget Android Devices in 150+ Countries appeared first on SecurityWeek .

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.securityweek.com/pre-baked-firmware-malware-hits-budget-android-devices-in-150-countries/>

06. [+24h Old] US Disrupts Chinese State-Sponsored Hacking Tools

Flax Typhoon and other APTs used MicroScan and FishHub to scan and hack US and foreign critical infrastructure. The post US Disrupts Chinese State-Sponsored Hacking Tools appeared first on SecurityWeek .

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.securityweek.com/us-disrupts-chinese-state-sponsored-hacking-tools/>

07. [+24h Old] ISC Stormcast For Friday, October 9th, 2026

<https://isc.sans.edu/podcastdetail/10130>, (Fri, Oct 9th)

ISC Stormcast For Friday, October 9th, 2026 <https://isc.sans.edu/podcastdetail/10130>, (Fri, Oct 9th)

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://isc.sans.edu/diary/rss/33412>

08. [+24h Old] Low-cost Android phones ship with residential proxy malware

A malware campaign dubbed 'Midnight Mimosa' has been discovered on low-cost Android smartphones that ship with malicious software embedded in their firmware, allowing attackers to silently install apps, perform ad fraud, and turn devices into residential proxies. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.bleepingcomputer.com/news/security/low-cost-android-phones-ship-with-residential-proxy-malware/>

09. [+24h Old] Venezuelan Cartel's Malware Honcho Nabbed for ATM Jackpotting

The first cybercriminal to ever make the FBI's "10 Most Wanted Fugitives" list allegedly infused Tren de Aragua's violent criminal operations with cash.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.darkreading.com/cyberattacks-data-breaches/venezuelan-cartel-malware-honcho-nabbed-atm-jackpotting>

10. [+24h Old] Russian Spies Give 'MatchBoil' Malware a Stealthy Facelift

Cyber-espionage actor UAC-0099 has been steadily refining its flagship dropper in campaigns targeting Ukrainian organizations.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources:

<https://www.darkreading.com/cyberattacks-data-breaches/russian-spies-matchboil-malware-facelift>

Latest Vulnerabilities (10)

01. Credential-Stealing GitHub Actions Workflows Planted in Tens of Thousands of Repositories

Cybersecurity researchers have disclosed details of an ongoing credential-theft campaign that has compromised two high-profile open-source maintainer accounts to push a malicious workflow into over 340 repositories. "Using the account of Takashi Kitao, author of the 18,400-star game engine pyxel, the attacker pushed a malicious workflow to 27 repositories s...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://thehackernews.com/2026/10/credential-stealing-github-actions.html>

02. SonicWall SSRF bug rated 10.0 exploited in SMA1000 Appliance Work Place Attackers target critical SonicWall SMA1000 flaw as security experts urge immediate patching.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources:

<https://www.scworld.com/news/10-0-sonicwall-ssrf-bug-now-exploited-in-sma1000-appliance-work-place>

03. Unpatched AhsayCBS flaws exploited to deploy webshells, mine crypto

Threat actors are exploiting one critical and one medium-severity vulnerability still unpatched in the AhsayCBS backup management platform to deploy webshells and cryptocurrency miners. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/unpatched-ahsaycbs-flaws-exploited-to-deploy-webshells-mine-crypto/>

04. P7 DarkSword iOS Exploit Kit Adds Crypto Wallet Data Theft and Remote Commands

Cybersecurity researchers have disclosed details of a previously unseen variant of the DarkSword iOS exploit kit called P7 DarkSword. "Compared with the variants we usually observe, P7 reduces its on-device footprint, adds on-device keychain and crypto-wallet theft, and adds two way C2 communication with the attacker's infrastructure," iVerify said in a new...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://thehackernews.com/2026/10/p7-darksword-ios-exploit-kit-adds.html>

05. Lightwell project filters out 400 Java library vulnerabilities

Lightwell, the open-source security initiative set up by IBM and Red Hat, has identified more than 400 previously undiscovered vulnerabilities in widely used Java libraries - and now the companies are inviting customers to submit their own code dependencies to a new service, Lightwell Clearinghouse, for review. They'll be looking for bugs such as the critic...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.csoonline.com/article/4233240/lightwell-project-filters-out-400-java-library-vulnerabilities-2.html>

06. OpenAI reports three new incidents of misalignment

OpenAI continues to report incidences of “misaligned” behavior by its AI models, with three new reports dropping on Oct. 2. However, they describe relatively minor issues compared to previous alignment reports and notices covering its attacks on Hugging Face , Rubygems , and a German programming wiki...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources:

<https://www.csoonline.com/article/4233207/openai-reports-three-new-incidents-of-misalignment.html>

07. Citrix issues its weekly critical security patch for NetScaler ADC and NetScaler Gateway

For the third week running, Citrix has issued a critical security warning to customers managing their own NetScaler ADC and Netscaler Gateway instances, this time warning of a memory overflow vulnerability enabling denial of service or remote code execution. This week’s vulnerability affects ADC and Gateway when configured as a SAML (Security Assertion Mark...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.csoonline.com/article/4233187/citrix-issues-its-weekly-critical-security-patch-for-netScaler-adc-and-netscaler-gateway-2.html>

08. How to keep AI agents within their permissions

AI agents can use valid credentials to perform actions beyond their assigned permissions, creating risks that traditional access controls may not prevent. Token Security explains how organizations can enforce agent-specific policies without sacrificing autonomy. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources:

<https://www.bleepingcomputer.com/news/security/how-to-keep-ai-agents-within-their-permissions/>

09. Researchers Publish Working Exploit for Pre-Auth AnyDesk Linux Flaw That Gives Root Access

Security researchers have published a full working exploit for a pre-authentication remote code execution flaw in AnyDesk Linux that gives attackers root access before anyone approves the connection. AnyDesk patched the flaw in version 8.0.3 in June, but its changelog described the fix only as “fixed a bug that could lead to a crash,” with no CVE assigned a...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://thehackernews.com/2026/10/researchers-publish-working-exploit-for.html>

10. Anthropic Launches Free AI Vulnerability Scanner for Open-Source Projects

Anthropic on Thursday unveiled OSS Scanner as an opt-in vulnerability scanner to help secure the open-source ecosystem using artificial intelligence (AI). "It's an opt-in service informed by our experience using Claude to find vulnerabilities during Project Glasswing," Anthropic said. "Projects that join will receive thorough, periodic security scans by our..."

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://thehackernews.com/2026/10/anthropic-launches-free-ai.html>

Data Breach & Cybercrime (10)

01. FBI Arrests Founder of Ransomware Negotiation Firm

Agents with the Federal Bureau of Investigation (FBI) on Thursday arrested the co-founder of a Canadian cybersecurity firm in connection with an investigation into the ShinyHunters hacking group that recently relieved the FBI of sensitive data on thousands of agents, multiple sources tell KrebsOnSecurity.

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://krebsonsecurity.com/2026/10/fbi-arrests-founder-of-ransomware-negotiation-firm/>

02. ASOS Breach Reveals the Risks in Customer-Facing SaaS

The attack on the British retailer shows that compromising a single identity can lead to much deeper penetration of the corporate network.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources:

<https://www.darkreading.com/cyberattacks-data-breaches/asos-breach-risks-customer-facing-saas>

03. Small construction firm collapses after ransomware attack, while another narrowly avoids disaster

According to The Register, a cybersecurity consultant shared two cautionary tales highlighting the critical importance of robust security measures, one involving a devastating ransomware attack on a small construction company and another detailing a sophisticated phishing attempt that was thwarted by advanced security software.

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.scworld.com/brief/small-construction-firm-collapses-after-ransomware-attack-while-another-narrowly-avoids-disaster>

04. FBI Arrests Another ShinyHunters Suspect Reportedly Involved in Its Jobs Portal Hack

The FBI has arrested another suspected co-conspirator of ShinyHunters, FBI Director Kash Patel said on October 9 in a post on X. ShinyHunters is the extortion group that said in September it had breached the FBI's jobs portal and stolen sensitive data on almost all FBI agents and job applicants. The FBI has not named the suspect, and no charges have been ma...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://thehackernews.com/2026/10/fbi-arrests-another-shinyhunters.html>

05. What We Missed: FBI Strikes Back at ShinyHunters

In this video conversation, Dark Reading editors discuss some of the news they didn't get a chance to cover, from the arrest of a suspected ShinyHunters operative to the compromise of a Pentagon-run data center.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources:

<https://www.darkreading.com/identity-access-management-security/fbi-shinyhunters-claims-hack>

06. FBI arrests another suspected ShinyHunters hacker after agency breach

The FBI has arrested another suspected member of the ShinyHunters extortion group believed to be involved in the recent breach of FBI systems, Director Kash Patel announced Friday. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/fbi-arrests-another-suspected-shinyhunters-hacker-after-agency-breach/>

07. Ransomware consultant said he would decrypt data, is accused of paying ransoms instead

The owner of a ransomware remediation company is facing trial for defrauding customers. Zohar Pinhasi, also known as “Zack Silver” and “Zack Green,” has been arraigned in New York on wire fraud charges for allegedly defrauding clients of his ransomware remediation company, MonsterCloud. Pinhasi falsely claimed he could recover documents encrypted by ransomw...

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.csoonline.com/article/4233219/ransomware-consultant-said-he-would-decrypt-data-is-accused-of-paying-ransoms-instead.html>

08. Germany arrests alleged core Qilin ransomware member after extradition

Germany has arrested a Russian national suspected of being a leading member of the Qilin ransomware group following extradition from Japan earlier this month. [...]

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.bleepingcomputer.com/news/security/germany-arrests-alleged-core-qilin-ransomw-are-member-after-extradition/>

09. In Other News: AI Used in Korean Bank Breaches, Poem-Guided Botnet, Empire Admin Gets 40 Years

Noteworthy stories that might have slipped under the radar: Tensorlake npm SDK compromised, Empire Market co-founder gets 40 years, exposed NVIDIA GPU monitors leak telemetry. The post In Other News: AI Used in Korean Bank Breaches, Poem-Guided Botnet, Empire Admin Gets 40 Years appeared first on SecurityWeek .

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.securityweek.com/in-other-news-ai-used-in-korean-bank-breaches-poem-guided-botnet-empire-admin-gets-40-years/>

10. Q3 2026 Sets New Record for Ransomware Attacks

Comparitech observed 2627 claimed ransomware attacks in Q3, with critical sectors like finance, technology, education and healthcare experiencing significant increases

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.infosecurity-magazine.com/news/q3-new-record-ransomware/>